

Phishing Campaign Analysis Report

Executive Summary

This report analyzes a financially-themed phishing campaign that delivered **Agent Tesla** (MSIL/AgentTesla), a .NET-based remote access trojan and credential stealer. The phishing emails, disguised as "Statement of Account" correspondence, contained a malicious ZIP file attachment. Upon execution, the malware attempted to steal credentials, monitor user activity, and exfiltrate data to attacker-controlled infrastructure.

Risk Level: HIGH. The campaign poses severe risks including credential theft, financial fraud, regulatory exposure, and reputational damage. Immediate containment and long-term security enhancements are required.

Scope & Timeline

- **Artifacts analyzed:** Phishing emails, attachments (**STATEMENT OF ACCOUNT.zip**), extracted executables, PCAP traffic.
- **Dates of analysis:** September 22, 2023 (simulation) and September 16, 2025 (follow-up).
- **Objective:** Identify delivery method, payload behavior, and business risks; provide tactical and strategic recommendations.

Methodology

- **Controlled environment:** Analysis in isolated VMs (Kali Linux, VMware).
- **Email parsing:** .eml files parsed to extract headers, attachments, and URLs.
- **Static analysis:** File hashing (SHA-256), VirusTotal scanning, WHOIS and IP reputation lookups.
- **Dynamic/network review:** Wireshark PCAP analysis for DNS and C2 communications.
- **Cross-validation:** Findings correlated with multiple threat intelligence sources.

Findings

1. Delivery & Deception (Phishing Tactics)

- **Subject line:** "RE: SOA as at 20th September 2023"
- **Lure:** Fake financial documents designed to trigger quick response from Finance/Accounts staff.
- **Social engineering:** Urgent language, reply-chain formatting, generic greetings, and requests for remittance confirmation.

2. Header & Source Analysis

- **Authentication failure:** `spf=fail` → spoofed sender domain (**coretek.cn**).
- **Originating IP:** `193.42.33.171` (Slovakia). Flagged as "Worst Offender" by SpamRATS due to sustained malicious behavior.
- **Domain reputation:** `coretek[.]cn` registered to Shenzhen Lingfei Technology Co. Ltd. — no inherent malicious reputation, but spoofed.

3. Malicious Payload (Agent Tesla)

- **Attachment:** `STATEMENT OF ACCOUNT.zip`
 - **SHA-256:**
`e0b82e45a3f9730b6a4984918864330c7783b90f9a88276d18146587d5657ce8`
- **Extracted EXE:** `STATEMENT OF ACCOUNT.exe`
 - **SHA-256:**
`7a7c13b3a488e5198ef87d64a8e7cb54a8bb5eade1cbfb7a76888a8b7a6353b`
- **VirusTotal verdict:** 50/67 detections → Agent Tesla / MSIL.Krypt variants.

Capabilities of Agent Tesla:

- Keylogging and clipboard capture
- Credential harvesting (browsers, email, VPN, FTP)
- Screen capture and host profiling
- Exfiltration over HTTP/HTTPS, SMTP, FTP, or Telegram
- Evasion via basic VM and antivirus checks

4. Infrastructure & Command & Control

- **Identified C2 IPs:**
 - 104[.]237[.]62[.]212
 - 162[.]241[.]169[.]155
 - 93[.]184[.]221[.]240
 - 173[.]254[.]28[.]237 (resolves mail[.]expertsconsultgh[.]co)
- **Auxiliary service:** api.ipify.org (legitimate) used to determine victim external IP.
- **Inference:** Rotating infrastructure; multiple live endpoints active in related campaigns.

Risk & Impact Assessment

Threat Level: HIGH

Potential business impacts:

- **Financial fraud:** Stolen credentials → fraudulent transfers, invoice tampering.
- **Data breach:** Theft of sensitive documents, customer/partner information, intellectual property.
- **Lateral movement:** Use of stolen credentials to spread across systems or deploy ransomware.
- **Reputational harm & compliance risk:** Regulatory fines, breach notifications, customer trust loss.

Recommendations

Immediate Tactical Actions

- **Quarantine:**
 - ZIP SHA-256:
[e0b82e45a3f9730b6a4984918864330c7783b90f9a88276d18146587d5657ce8](#)
 - EXE SHA-256:
[7a7c13b3a488e5198ef87d64a8e7cb54a8bb5eade1cbfb7a76888a8b7a6353b](#)
- **Block:** Malicious IPs/domains at firewall, DNS, SWG, and EDR.
- **Isolate:** Hosts that interacted with suspicious attachments.

- **Credential resets:** Force resets across AD, email, VPN, and finance portals.

Strategic Enhancements (30–60 days)

- Enforce **DMARC** with quarantine/reject.
- Implement **attachment sandboxing**; block external ZIPs with executables.
- Expand **EDR deployment** with behavior-based detection.
- Improve **DNS filtering** and TLS inspection.
- Conduct targeted **phishing awareness** training for finance staff.
- Update **SIEM rules** to detect infostealer behaviors.

MITRE ATT&CK Mapping

- **Initial Access:** Phishing – Attachment (T1566.001)
- **Execution:** User Execution (T1204)
- **Credential Access:** Credentials from Browsers (T1555.003), Keylogging (T1056.001)
- **Discovery:** System Information (T1082)
- **Exfiltration:** Exfiltration Over C2 Channel (T1041)
- **C2:** Application Layer Protocol (T1071)

Conclusion

The campaign showcases the enduring effectiveness of phishing paired with commodity malware. The attachment conclusively matched **Agent Tesla**, with supporting infrastructure for exfiltration and control. Organizations should treat this as a **priority incident type**, combining **immediate blocking** and **host isolation** with **strategic hardening** of email and endpoint defenses.

Appendix A – Indicators of Compromise (IOCs)

Type	Indicator	Notes
File Hash	e0b82e45a3f9730b6a4984918864330c7783b90f9a88276d1	Malicious ZIP (Agent Tesla)
File Hash	7a7c13b3a488e5198ef87d64a8e7cb54a8bb5eadef1cbfb7a7	Extracted executable (Agent Tesla)
IP	193.42.33.171	Sender IP – spoofed origin
IP	104.237.62.212	C2 Server
IP	162.241.169.155	C2 Server
IP	93.184.221.240	C2 Server
IP	173.254.28.237	C2 Server (mail.expertsconsultgh.co)
Domain	coretek.cn	Spoofed sender domain
Domain	mail.expertsconsultgh.co	C2 domain
Service	api.ipify.org	Legitimate service used by malware

Appendix B – Control Checklist

- Quarantined all suspicious attachments
- Blocked IOCs at firewall, DNS, proxy, EDR
- Reset credentials for at-risk accounts
- Reimaged compromised hosts
- Enforced DMARC/SPF/DKIM alignment
- Enabled attachment sandboxing and blocked risky file types
- Verified EDR coverage
- Conducted finance-specific phishing training
- Logged incident with Legal/Compliance

Agent Tesla Attack Chain

